Triaje de nivel 1 asistido por IA para el SOC de Tarvia

Propuesta al Comité de Dirección · Equipo Prompt & Pray · noviembre de 2026

11.061
alertas del SIEM en 4 semanas

32 %
llegan fuera del horario del SOC (8–20 h, L–V), sin nadie mirando

96 %
vienen de solo 9 reglas, casi todas ruido repetido

~19 s
por alerta con IA; el SLA de una alerta crítica es de 15 min

El problema

- Seis analistas, de 8 a 20 h entre semana. Una alerta crítica a las 3 de la madrugada espera hasta el lunes, o hasta que la guardia N2 se entere.
- El volumen lo dominan unas pocas reglas ruidosas: el equipo se pasa el día cerrando lo mismo y lo importante se pierde.
- Lo que más importa proteger: la venta online, los datos de los clientes, los pagos y la logística.

Qué hace el sistema, alerta por alerta

- **Reúne las pruebas** que pide el runbook de cada regla: logs ±24 h, inventario, cambios aprobados, RR. HH., inteligencia, otras alertas.
- **La IA las juzga**: veredicto, resumen para N2 y las pruebas citadas por su identificador. Si no puede decidir, lo dice y pasa a una persona.
- **El código aplica la política del SOC**: severidad con la matriz, SLA, escalado obligatorio y quién aprueba cada acción.
- **Una persona decide** en una consola web: ve qué se consultó, por qué y qué tiene que aprobar.
- Agrupa las 11.061 alertas en **215 decisiones de la IA**: el ruido repetido se juzga una vez y se copia a sus iguales tras comprobar cada uno.

Riesgos y cómo se controlan

- **La IA se equivoca**: nunca ejecuta nada; si falla o duda, la alerta pasa a una persona y, si es grave, se escala.
- **Un atacante intenta engañarla**: el texto del atacante se aísla como dato y no se obedece.
- **Exceso de confianza**: medimos con alertas que no se usaron para ajustar; las limitaciones están documentadas.

Quién decide qué

Decisión	IA	Persona / código
Recoger y cruzar pruebas	sí (solo lectura)	—
Veredicto y resumen	propone, citando pruebas	el analista acepta o corrige
Severidad, SLA, escalado	aporta hechos	la política (código)
Contención (bloquear, aislar…)	solo propone	una persona, con un clic
Red OT (clasificador de Martorell)	nunca actúa	Operaciones

Resultados medidos

- **Fiabilidad**: las 11.061 alertas cubiertas con 245 tickets válidos y 0 errores; las 215 decisiones de la IA en ~9 minutos (8 en paralelo).
- **Acierto** sobre 12 alertas etiquetadas que nadie usó para ajustar: **83 % de veredictos (10 de 12)**, **ningún ataque no detectado y ningún escalado perdido**. Sobre las 61 usadas para ajustar (cifra optimista): 95 % de veredictos, 0 ataques no detectados y 0 de 36 escalados perdidos.
- **Manipulación**: correos con instrucciones ocultas para el «sistema automático» se detectan y no se obedecen.
- **Criterio**: distingue un ataque, una actividad autorizada (pentest, escáner, mantenimiento con cambio aprobado) y una falsa alarma rutinaria.

Lo que gana Tarvia

- Triaje 24/7 dentro del SLA; las noches y los fines de semana dejan de ser un punto ciego.
- Ajuste de reglas con datos: **un solo patrón rutinario (inventario de software) genera 1.349 alertas (12 %)**; excluirlo las elimina en origen.
- Cada decisión queda documentada y es auditable (pruebas, consultas, cálculo de severidad).

Qué pedimos al Comité

- Un **piloto de 4 semanas en modo sombra**: la IA tría, el equipo compara, nada se automatiza.
- Aprobar las **exclusiones de reglas** que proponga el piloto (empezando por el inventario rutinario).
- Que la **guardia N2** reciba de noche los escalados críticos del sistema.
- Una revisión de resultados al final del piloto antes de ampliar el alcance.

Datos sintéticos del reto (octubre de 2026). Modelo de lenguaje en la pasarela de la UAB, sin coste para Tarvia. Detalle técnico y limitaciones: README y docs/limitations.md del proyecto.